

MANAGEMENT DECISIONS REQUIRED

CareFirst Third Party Booking System

Prepared **2026-05-21** by the development team

Following the 2026-05-21 system audit closeout (28 of 30 audit findings resolved in code)

The development team has just completed a substantial cleanup pass on the booking system — 28 security and quality findings from the system audit have been resolved and shipped to production. **Seven items remain that cannot be closed by engineering alone**; they need a decision, approval, or coordination from outside the development team. This document summarises each one in plain language so leadership can review, ask questions, and respond.

HOW TO READ THIS DOCUMENT

Each item below has the same structure: **what we're asking**, **why it matters**, **the options on the table**, the team's **recommendation** (where we have one), and **the specific action we need from you**. The impact tags (**HIGH** **MEDIUM** **LOW**) indicate business or compliance impact, not technical effort.

1

Choose a production domain and switch the site to HTTPS

HIGH

WHAT WE'RE ASKING

The site is currently reachable only at `http://187.127.135.11:3000` — an IP address with no encryption. We need a real domain (e.g. `booking.firstcare.solutions`) attached and traffic encrypted before this can safely be used for real patient information at scale.

WHY THIS MATTERS

Today every login, every patient record, every payment confirmation travels across the network unencrypted. Anyone in a position to observe the network (public Wi-Fi at a clinic, an upstream internet provider, a malicious actor on the same network) can read or tamper with it. South Africa's POPIA law explicitly requires encryption of patient data in transit. The app code is already prepared to flip into "HTTPS mode" the moment the encryption is in place; we just need the domain.

WHAT WE NEED FROM YOU

- A decision on the domain (does the brand team have a preferred subdomain?).
- Access to whoever manages the DNS for `firstcare.solutions` (or whichever domain we choose) so we can point it at our server.
- Sign-off that we're ready to attach the brand to this live system.

EFFORT ONCE UNBLOCKED Half a day, mostly waiting for DNS propagation. The encryption certificate is free (Let's Encrypt) and renews automatically.

Decide our POPIA “right to erasure” stance HIGH

WHAT WE'RE ASKING

When a patient requests their data be deleted under POPIA, our system removes their personal details but keeps one piece of information — the **clinic unit** they booked through — for billing reconciliation. Strictly speaking, that piece of information, combined with the date of the deletion and other public records, could theoretically be used to re-identify the patient. We need to decide how to handle this.

WHY THIS MATTERS

Our privacy notice promises “we delete everything that identifies you.” The current implementation can be challenged on that promise if a complaint is ever lodged with the Information Regulator. The risk is low in practice but not zero, and the cleanest position is to make an explicit choice and document it.

OPTIONS ON THE TABLE

- **(A) Accept the residual risk and update the privacy notice** to be transparent that we retain unit-level billing data after erasure. Lower engineering cost, higher compliance-conversation cost.
- **(B) Replace the unit identifier post-erasure with a broader code** (e.g. just the client's overall code rather than the specific clinic unit). Higher engineering cost (half a day), cleaner compliance story.

WHAT WE NEED FROM YOU A stakeholder conversation with legal / the data protection officer to pick between (A) and (B). Either is defensible — the question is which posture the business wants to take.

Confirm the payment gateway is in the correct mode HIGH

WHAT WE'RE ASKING

The PayFast payment gateway has two modes: **sandbox** (test transactions, no real money) and **live** (real cards, real money). Our system has a setting called `PAYFAST_TEST_MODE` that controls which one is used. We need finance / ownership to confirm which mode should be active in production right now.

WHY THIS MATTERS

If we are still in sandbox mode but actual paying patients reach the site, no money will actually be collected. Conversely, if we are in live mode prematurely, test bookings could accidentally charge real cards. Today's smoke tests all ran against the sandbox merchant account.

WHAT WE NEED FROM YOU A simple yes/no from finance: should we be in live mode or sandbox right now? If live, we also need to confirm we have the right merchant credentials in place.

Decide whether to upgrade our database provider plan

MEDIUM

WHAT WE'RE ASKING

Our database and authentication provider (Supabase) currently sits on their free tier. Upgrading to the Pro plan (~£20–25 per month per project) would unlock two additional security features: **session time-boxing** (force a user to re-sign-in after, say, every 12 hours) and **idle auto-sign-out enforced at the database level**. We already have an in-app idle timer that covers the basics, but the platform-level controls add a safety net.

WHY THIS MATTERS

Not blocking anything today — we have functional alternatives. The question is whether the additional defence-in-depth (a few extra layers of automatic sign-out) is worth the small monthly cost. Also relevant for future scale, as the Pro plan increases database capacity limits.

OUR RECOMMENDATION Worth the cost. Most production-grade systems run on at least the Pro tier of their backend-as-a-service provider, and the security improvements compound over time. Not urgent though — can be done at the next budget review.

WHAT WE NEED FROM YOU Sign-off (or rejection) on the recurring ~£20–25/month cost.

5

Coordinate with the CareFirst Patient team on two follow-ups **MEDIUM**

WHAT WE'RE ASKING

Our system hands patient bookings over to the CareFirst Patient app for the actual consultation. Two operational items surfaced during today's testing that need coordination with the CareFirst operations team:

- The staging tenant's consult **service credits have been used up**, so end-to-end tests can't complete (the booking succeeds on our side, the consult never starts on theirs).
- During concurrent-click testing earlier today, before we deployed the fix, we inadvertently created **duplicate patient sessions** on CareFirst's side for one test booking. CareFirst ops may want to clean those duplicates out.

WHY THIS MATTERS

Neither item blocks production code, but both prevent us from doing fully end-to-end rehearsal of the patient journey ahead of go-live. The duplicate-session item is also worth flagging proactively so it doesn't surface as a data-cleanup question later from their side.

WHAT WE NEED FROM YOU An introduction or warm handoff to the right person on the CareFirst Patient team for operational coordination. We can take it from there.

Approve the approach for background housekeeping jobs

LOW

WHAT WE'RE ASKING

The system needs three small background “housekeeping” jobs to run every 15 minutes — rechecking the payment gateway for missed payments, clearing the “incidents” banner when problems resolve, and tidying up old session records. Today these only run when an admin happens to open certain pages. We need a small scheduler to fire them automatically.

WHY THIS MATTERS

At today's low booking volume, nothing breaks — an admin checks in often enough. As volume grows, payments can sit in “limbo” until someone manually clicks “Check PayFast for new payments,” and old security records pile up forever. The self-healing premise of the audit fixes relies on these sweeps running regularly.

OUR RECOMMENDATION Use a standard Linux scheduler (cron) on the server we already operate. Simplest possible setup, no extra cost. Effort: half a day including a small alert if it ever stops firing.

WHAT WE NEED FROM YOU Just acknowledgement that we're proceeding with the recommended approach (or objection if you'd prefer something more sophisticated like a managed scheduler).

Decide how we cover real-device testing LOW

WHAT WE'RE ASKING

The audit and today's smoke test were both done on desktop Chrome. We have no verified coverage on iPhone Safari, Android Chrome, older Edge versions, or Firefox. For a clinic-facing tool that nurses may operate on a mix of devices, that gap is worth closing.

OPTIONS ON THE TABLE

- **(A) Physical devices** — have one or two team members spot-check on their own phones and tablets. Free, but not systematic.
- **(B) Browser-testing service** (BrowserStack, LambdaTest, Sauce Labs) — ~£30–100/month, lets us script tests against dozens of real device combinations.
- **(C) Defer** — accept the risk until a real device-specific bug surfaces, then react.

OUR RECOMMENDATION (A) initially — a one-off spot-check from a couple of team members on their own devices costs nothing and catches the obvious issues. Revisit (B) only if we hit a real device-specific bug in production.

WHAT WE NEED FROM YOU A nod that (A) is acceptable, or alternatively budget for (B).

Document version: 1.0 · Prepared: 2026-05-21

Status: All seven items are non-urgent in the sense that the system runs today, but each one represents either a compliance posture, an operational improvement, or a defence-in-depth measure that strengthens the platform.